MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 023 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · POA&M

What You Can Put on a POA&M, and What You Cannot

Under 32 CFR 170.21 a CMMC POA&M can carry only 1-point requirements, minus six named exclusions, and must close within 180 days. The rules.

BY **MAXINE** READING TIME · 5 MIN POAM · CMMC · SPRS · NIST-800-171

Plan of Action and Milestones reads, to most program managers filling one out for the first time, like a second chance: list what is not done yet, promise a date, and the assessment proceeds as if the gap were already closed. It is not a second chance. It is a narrow, rule-bound exception to the requirement that every control be implemented before certification, and the rule that bounds it, 32 CFR 170.21, is stricter than the paperwork suggests. It sets a score floor, a point ceiling, a list of named exclusions, and a single deadline.

What a POA&M cannot buy you

Start with the score, because it is the number a contracting officer actually reads. The DoD Assessment Methodology subtracts a weight of 5, 3, or 1 for every unimplemented control, and the subtraction does not know the difference between a control nobody has touched and a control with a signed remediation plan behind it - see how that arithmetic actually runs. It stays in effect until the control is implemented, not until it is planned. Write a POA&M for a gap and the score posted to SPRS is still the lower number.

The second limit removes the option entirely for most of the requirement set. For Conditional Level 2 status, whether self-assessed or C3PAO-assessed, 170.21(a)(2) allows a POA&M only when three conditions all hold. The assessment score must be at least 0.8 of the 110 requirements, which is 88. No requirement on the POA&M may carry a point value greater than 1. And none of six named requirements may appear on it at all, even though each is worth a single point: external connections (3.1.20), control of public information (3.1.22), the system security plan itself (3.12.4), and three physical protections - escorting visitors, physical access logs, and managing physical access devices (3.10.3 through 3.10.5).

That point ceiling is the rule programs misread most. It does not bar a handful of famous controls; it bars every 3-point and 5-point requirement in the set. 3.5.3, multifactor authentication, cannot go on a POA&M, and neither can its partial-credit state, because a partially implemented 3.5.3 still carries 3 points. The regulation makes exactly one exception, and it runs the opposite way from what many programs assume: 3.13.11 may be placed on a POA&M when encryption is employed but is not FIPS-validated, the state the methodology scores at 3 points. Encryption that is missing outright is worth 5 and gets no such allowance. A remediation plan built around deferring the expensive controls is not a remediation plan. It is a plan to fail the assessment on the items the DoD weighted heaviest for the same reason a program manager is tempted to defer them: they are the hardest to fake and the most expensive to fix.

Level 1 is simpler still. A POA&M is not permitted at any time for a Level 1 self-assessment.

One clock, and it ends in an assessment

What a POA&M can do is buy time on the requirements that remain eligible, and the time is not open-ended. There is a single window, not a tiered one: the POA&M must be closed, and the closing confirmed by a POA&M closeout assessment, within 180 days of the Conditional CMMC Status Date. Miss it and the Conditional status for that information system expires. Nothing about the clock cares whether the underlying work is hard, and nothing in the rule shortens or lengthens it by the priority a program assigns an item internally.

Closure is not a status an engineer sets in a spreadsheet. The closeout assessment examines only the NOT MET requirements that were carried on the POA&M, and who performs it follows the original assessment: the organization itself, in the same manner as the initial assessment, for a Level 2 self-assessment; an authorized or accredited C3PAO for a Level 2 certification assessment. Either way the question is whether the control now meets its NIST SP 800-171A assessment objectives, which means the remediation implemented and the evidence collected before the closeout begins, and the SPRS score updated once it passes.

An unowned action is an action nobody has agreed to take, and an assessor reads a POA&M line that way on sight.

FIELD COPY
ISSUE Nº 023
POAM

The rule does not dictate an owner column, but the 180-day window depends on one. A line item whose owner reads "TBD" or "IT" has not identified a person; it has identified a department, or an intention to figure it out later, and neither can be held to a date the regulation will not move. Nor does anything in 170.21 let a risk acceptance stand in for implementation - a requirement carried on the POA&M is NOT MET until the closeout assessment says otherwise.

None of this makes the document useless. An eligible 1-point gap with a real owner and a defensible date is a legitimate answer to a real deficiency, and it buys up to 180 days a program would not otherwise have. What it does not do is make an assessment easier than the underlying requirements actually are. A readiness check that sorts your open gaps into what is POA&M-eligible and what has to close before an assessor ever arrives is worth running before the plan gets written, not after it gets rejected.

Correction, September 13, 2026: An earlier version of this article said 3.5.3 and 3.13.11 were the barred 5-point requirements and that most others faced the same bar, and described separate 90-day and 180-day closeout clocks starting when the plan is filed. Under 32 CFR 170.21, every requirement worth more than 1 point is barred except 3.13.11 when encryption is employed but not FIPS-validated, six named 1-point requirements are also barred, a score of at least 88 is required, and there is one 180-day window from the Conditional CMMC Status Date, confirmed by a closeout assessment. The article has been revised throughout. ◆

1

THE HIGHEST POINT VALUE A LEVEL 2 POA&M ITEM MAY CARRY - WITH ONE EXCEPTION, 3.13.11 WHEN ENCRYPTION IS USED BUT NOT FIPS-VALIDATED

88

THE MINIMUM LEVEL 2 SCORE (0.8 OF 110) FOR CONDITIONAL STATUS AT ALL

180

DAYS FROM THE CONDITIONAL CMMC STATUS DATE TO PASS A POA&M CLOSEOUT ASSESSMENT, OR THE STATUS EXPIRES

◆ THE SIX 1-POINT REQUIREMENTS THAT STILL CANNOT WAIT

32 CFR 170.21(a)(2)(iii) bars these from a Level 2 POA&M regardless of weight - 3.1.20 external connections, 3.1.22 control public information, 3.12.4 system security plan, 3.10.3 escort visitors, 3.10.4 physical access logs, and 3.10.5 manage physical access.